



INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO



TRABAJO TERMINAL TT2026-B136

Núcleo criptográfico y aplicación local

Evidencia documental verificable por CLI y HTTP

Arquitectura hexagonal en Rust, validación automatizada y evidencia independiente.

Alonso Sánchez Eduardo | Vitales Herrera Hatziry

Directora: Sandra Díaz Santiago

Agosto de 2026

Qué demuestra este corte

PRUEBAS APROBADAS

394

COBERTURA GLOBAL

90.1 %

NONCES DISTINTOS

10,000

FALLOS

0

Alcance construido

- Diez capacidades criptográficas ejercitables desde CLI y HTTP.
- Separación entre dominio, casos de uso y adaptadores reales.
- Identidad persistida, RBAC y evidencia interoperable.

Criterio de lectura

- “Verificado” significa reproducido localmente.
- “Parcial” señala una dependencia externa u operativa.
- Identidad y RBAC ya se prueban; gestión procesal, alcance por caso y UI siguen pendientes.

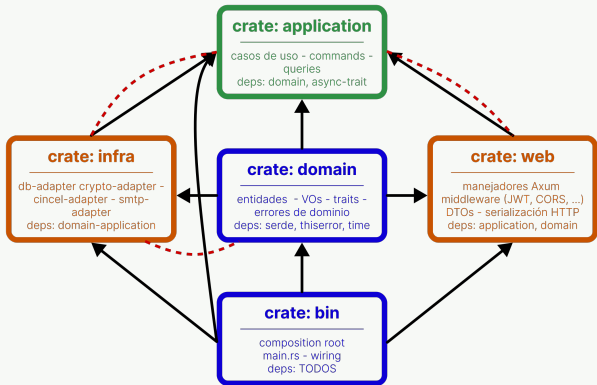
Arquitectura comprobable

Lectura del grafo

- Núcleo: `domain` y `application`.
- Adaptadores en `infra`; composición en `bin`.
- `web` conduce el puerto `DocumentWorkflow`.

Flecha sólida: permitida.

Línea roja: prohibida.



Capacidades criptográficas | primera parte

Capacidad	Evidencia principal	Estado
Integridad SHA-256	Hash por bytes y streaming; vectores oficiales y contraste con <code>sha256sum</code> .	VERIFICADO
Cifrado autenticado	AES-256-GCM, DEK por documento, KEK envolvente, AAD y rotación.	VERIFICADO
PKI interna	CA raíz, certificados RSA-3072, revocación y CRL mediante OpenSSL.	VERIFICADO
Firma digital	RSA-3072 con SHA-256 y PKCS#1 v1.5; interoperabilidad bidireccional.	VERIFICADO
Sellado RFC 3161	TSA local real; adaptador remoto cubierto por stub, sin dependencia de Cincel en la entrega.	PARCIAL OPERATIVO

Capacidades criptográficas | segunda parte

Capacidad	Evidencia principal	Estado
Verificación integral	Reporte de integridad, firma, certificado y sello con causas explícitas.	VERIFICADO
Credenciales Argon2id	Formato PHC; $m = 256$ MiB, $t = 2$, $p = 1$ y media de 529.4 ms en el host de referencia.	VERIFICADO
Segundo factor TOTP	Vectores RFC 6238, ventana de un periodo y códigos de recuperación.	VERIFICADO
Auditoría encadenada	Cadena SHA-256 persistida en JSONL y detección del índice alterado.	VERIFICADO
Paquete de evidencia	ZIP autocontenido con instrucciones para OpenSSL y unzip.	VERIFICADO

Estrategia de validación

Vectores

FIPS 180-4, GCM,
RFC 6238 y RFC
4226.

Propiedades

Entradas
generadas, nonces
y consistencia de
ida y vuelta.

Mutaciones

Documento, firma,
token, CRL,
paquete y bitácora
alterados.

Herramientas

OpenSSL,
sha256sum,
unzip y CLI real.

Dominio



Aplicación



Infraestructura



Extremo a extremo

La prueba observa tanto primitivas aisladas como su composición en un proceso real.

Resultados de pruebas y cobertura



Suite completa

395

funciones descubiertas

394 aprobadas

0 fallidas

1 ignorada

El umbral del 90 % aplica a los tres crates con lógica criptográfica; **web** reporta 73.2 % informativo. La prueba ignorada conserva la sonda externa, fuera de la evidencia actual por inestabilidad y costo no transparente.

Demostraciones integrales reproducidas

1. Crear la CA, el firmante y la TSA local.
2. Recorrer por CLI criptografía, revocación y autenticación.
3. Levantar PostgreSQL, Redis y la aplicación HTTP.
4. Crear usuarios; completar TOTP y comprobar RBAC.
5. Cargar y persistir el documento únicamente cifrado.
6. Firmar, sellar, verificar y exportar la evidencia.

```
$ bash scripts/demo.sh
$ bash scripts/api-demo.sh

integrity: passed
signature: passed
certificate: passed
timestamp: passed
verdict: valid

Verified OK
certificado.pem: OK
Verification: OK

Authenticated API demo passed.
```

Identidad y autorización atraviesan la API

Estado duradero | PostgreSQL

- Cuenta, Argon2id, rol y estado activo.
- TOTP cifrado y recovery hasheado.
- Bootstrap atómico y revisión optimista.

Estado efímero | Redis

- Sesiones opacas revocables con TTL.
- Desafíos MFA de un intento por 5 minutos.
- Bloqueo de login y rechazo de replay TOTP.

RBAC conservador

Owner administra y sella; Litigante opera documentos; Paralegal crea, verifica y exporta; Cliente queda cerrado hasta persistir pertenencia a casos.

Authorization: `Bearer` determina actor y permisos; `X-Actor` fue retirado.

Riesgo materializado: dependencia del PSC

Acceso

El registro en el entorno del proveedor pudo completarse.

Operación

La API no mostró estabilidad suficiente para una campaña repetible.

Costo

El sandbox requiere pago y no ofrece precios transparentes para presupuestar una campaña.

La materialización no ocurrió en el registro, sino durante el consumo.

- Una falla externa puede confundirse con una regresión del adaptador.
- La suite y la demostración perderían reproducibilidad.
- Los reintentos y la campaña de tokens introducen costo variable.

Estado: TSA local para la evidencia; adaptador remoto opcional y sin contrato externo confirmado.

Mitigación: TSA interna intercambiable



- Certificado RSA-3072 exclusivo para `timeStamping`.
- Tokens RFC 3161 reales, no respuestas simuladas.
- Verificación independiente con OpenSSL.

Regla operativa

Sin conmutación silenciosa: el emisor y su ancla de confianza quedan identificados en cada flujo.

Pruebas reproducibles sin red ni costo externo.

Alcance de la mitigación y riesgo residual

La TSA interna sí demuestra

- Solicitud y emisión conforme a RFC 3161.
- Vinculación del token con el digest.
- Firma, cadena y almacenamiento DER.
- Interoperabilidad del flujo completo.

La TSA interna no sustituye

- La independencia de un tercero.
- La estabilidad contractual de un PSC.
- Una constancia NOM-151 externa.
- Una constancia externa que se decida contratar posteriormente.

Continuidad técnica demostrada; evidencia externa fuera del alcance actual.

La arquitectura permite sustituir el adaptador sin modificar dominio ni casos de uso.

Límites abiertos del corte

Proveedor de sellado

La evidencia externa queda fuera del alcance actual. Un PSC futuro requerirá contrato, estabilidad y precios verificables.

Calibración Argon2id

$m = 256$ MiB, $t = 2$, $p = 1$:
529.4 ms en el host de referencia, dentro de banda. Repetir si cambia el hardware.

Web y persistencia

Identidad y RBAC entregados. Faltan alcance por caso, persistencia documental transaccional, consultas y UI.

Interpretación

El núcleo y la aplicación multiusuario local están implementados y probados. La TSA local cierra la demostración técnica; el frente restante es gestión procesal, autorización por recurso, persistencia documental y UI.

La aplicación multiusuario ya integra el núcleo sin trasladar criptografía ni reglas de dominio a la capa web.

Implementación, evidencia y documentación coinciden en el mismo corte.

`docs/verification-report.md`

Entregables

- Reporte y presentación actualizados.
- Informe de verificación local.
- Transcripción de demostración.